

Digital Policy Office

INFORMATION SECURITY

Practice Guide for Destruction and Disposal of Storage Media

Version 1.6

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the HKSAR.
--

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Alignment with Security Regulations (SR), Baseline IT Security Policy (S17) v.6 and IT Security Guidelines (G3) v.8 which were revised and promulgated in December 2016.	Whole document	1.1	May 2017
2	Revised in accordance with the classification of government IT security document.	Annex D	1.2	June 2020
3	Include suggested number of round of overwrite for data destruction with overwriting and included security consideration for disposal of storage media.	Pages 6-7 Annex D	1.3	August 2020
4	Alignment with IT Security Guidelines (G3) v.9	Page 7 Annex E	1.4	June 2021
5	Alignment with IT Security Guidelines (G3) v.9.1	Annex E	1.5	August 2022
6	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		1.6	July 2024

Table of Contents

1.	Introduction.....	1
1.1	Purpose.....	1
1.2	Normative References.....	1
1.3	Terms and Convention.....	2
2.	Common Best Practices	3
2.1	Plan and Execute.....	3
2.2	Checks and Balances.....	4
3.	Data Destruction Methods	6
	Annex A: Sample Template of Record of Secure Disposal of Storage Media.....	8
	Annex B: Sample Record of Secure Disposal of Storage Media Performed by In-house Staff .	10
	Annex C: Sample Record of Secure Disposal of Storage Media Performed by Outsourced Contractor	11
	Annex D: Security controls to prevent data loss during media disposal	12
	Annex E: Relevant IT Security Policies and Guidelines	13

1. Introduction

In accordance with government IT security policy and guidelines, Bureaux and Departments (B/Ds) are responsible to protect classified data, including personal data, from unauthorised access or unintentional disclosure. As a general principle, government information without any security classification should also be protected from unintentional disclosure. Data life cycle management is a policy and procedure based approach to managing data throughout its lifecycle, from creation and initial storage to the time when it becomes obsolete and is destroyed. When the data is no longer needed, it should be permanently destructed. Verification should be done to ensure the data in all active storage or archives has been destructed.

1.1 Purpose

This Practice Guide describes industry best practice for destruction and disposal of storage media and provides samples of checks and balances procedures including example data erasure certificates as official records to ensure proper completion of data erasure before the computer equipment and storage media are to be reused, transferred or disposed.

1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Baseline IT Security Policy [S17], the Government of the Hong Kong Special Administrative Region
- IT Security Guidelines [G3], the Government of the Hong Kong Special Administrative Region

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3 and the following apply.

Abbreviation and Terms	
B/Ds	Bureaux and Departments
Degaussing	A method of sanitisation that applies physical or logical techniques that render target data recovery infeasible using demagnetising techniques to reduce the magnetic flux of the magnetic media to virtual zero by applying a reverse magnetising field. It is also called “demagnetising”.
Overwriting	A method of sanitisation that applies programmatic, software-based techniques to sanitise data in all user-addressable storage locations for protection against simple non-invasive data recovery techniques, typically applied through standard read and write commands to the storage device, such as by rewriting with a new value.
Physical Destruction	A method of sanitisation that renders target data recovery infeasible by means of shredding, pulverisation, grinding, incineration, or disintegrating the storage media into particles.

2. Common Best Practices

All classified data must be erased before computer equipment, storage media and electronic office equipment are to be reused, transferred or disposed.

It is important to maintain an effective method of managing the process of destruction and disposal. To the extent that electronic media is used to store classified information, B/Ds should adhere to records management rules, including records retention schedules. An audit trail log should be maintained of all media that have been disposed. The log should include the date, type of device, manufacturer, serial number (if any), sanitisation or destruction method used, way of disposal such as transferred for reuse, trade-in, replacement of faulty media or disposed. B/Ds are required to keep proper records on sample checks of erased storage media for future compliance audit.

B/Ds should also pay attention to manufacturer warranty or maintenance contracts, where vendors would exchange faulty hardware for new replacements. Written assurance that storage media will be handled securely and destructed following testing should be obtained prior to releasing faulting hardware which has held classified data. B/Ds may refer to Annex D for lists of security concern on destruction and disposal of storage media.

2.1 Plan and Execute

Step 1. Identify items need to be erased or destroyed

IT asset disposal refers to the replacement of faulty storage media, disposal IT products and trade-in of IT products. B/Ds should check whether sensitive or classified information had previously been processed and/or kept in the item(s), such as storage media, computer equipment and electronic office equipment (e.g. multi-function printers and photocopiers) that may have **storage media embedded** as auxiliary devices whose existence may not be readily apparent to users. If in doubt, it should be assumed that they had.

Step 2. Determine the method of destruction of storage media

The choice of destruction methodologies should be based on the risk posed by the sensitivity of the data being destroyed and the potential impact of unintentional disclosure. Methods are overwriting, degaussing and/or physical destruction, which are stated in Section 10.3(b) “Information Erasure” of IT Security Guidelines (G3).

Step 3. Identify the party to clear or destroy all data from storage media

The task of destroying all data from storage media can be performed by in-house staff or outsourced contractors. B/Ds should determine the appropriate way by considering factors, such as required skill sets, availability of tools/equipment, operational procedure, data confidentiality, safety as well as cost.

Data erasure should be performed in B/D's own premises as far as practicable. If it is necessary to transport the item(s) to destruction site, classified information shall be transmitted in a manner that prevents loss or unauthorised access. B/Ds should also erase data held in the storage media prior to transporting it to an offsite location for destruction, if possible.

Step 4. Erase or destroy all data from storage media

B/Ds should refer to Section 10.3(b) "Information Erasure" of IT Security Guidelines (G3).

2.2 Checks and Balances**Step 5. Perform sample check of the disposed items**

A system of checks and balances should be maintained to verify the successful completion of data erasure process. To ensure the process has been done properly, sample check of the process should be performed by another party/personnel who is/are not involved in the original disposal action.

For sample check on overwriting method, B/Ds should verify the disposal of storage media using a different product from the one used to perform the initial disposal by read back the contents of the storage media to verify that the overwrite process completed successfully.

For sample check on degaussing and physical destruction methods, B/Ds should verify that the secure deletion process has been performed by personnel who is competent to perform disposal functions and has followed the disposal procedure. Magnetic checker card can be regarded as an evidence of the secure deletion. In addition, at least 20% of disposed storage media should be sample checked.

Step 6. Prepare secure disposal of storage media record

The person who performs the data erasure of storage media should declare in the forms that the Section 10.3(b) "Information Erasure" of IT Security Guidelines (G3) have been complied with in performing the disposal of storage media. A sample template is given at **Annex A**.

Step 7. Keep filled-in records of secure disposal of storage media form for compliance audit on erasure of data

If in-house staff have carried out the data erasure then the process should be recorded with the verification results and stored with all other relevant documentation. A sample record of secure disposal of storage media performed by in-house staff is given at **Annex B**.

If a service contractor has processed the storage media, there should be a procedure for verification of data erasure, including the issuing of certificates. The verification results should be stored with all other relevant documentation issued by the service contractor. A sample record of secure disposal of storage media performed by outsourced contractor is given at **Annex C**.

3. Data Destruction Methods

The table below describes different methods of data destruction for different storage media. B/Ds should make risk-based decisions on which method is most appropriate based on the data type, risk of disclosure, and the impact if that data were to be disclosed unintentionally.

Media Types	Reuse including transfer for reuse	Disposal including trade-in, and replacement of faulty media
Non-volatile magnetic media such as hard disk drives, floppy disks, tapes, etc.	Overwriting	Overwriting or Degaussing or Physical Destruction
Non-volatile solid state memory such as USBs, memory cards, flash drives, solid state disks (SSD), etc.	Overwriting	Overwriting or Physical Destruction
Optical media – write once such as CDs, DVDs, Blu-ray discs, etc.		Physical Destruction
Optical media – write many such as CDs, DVDs, Blu-ray discs, etc.	Overwriting	Physical Destruction
Smart devices such as PDAs, phones, tablets, etc.	Overwriting	Overwriting or Degaussing or Physical Destruction

Notes:

For any media which has been used for the storage of information classified as higher than CONFIDENTIAL, apart from the above procedure of sanitising the media, it is also recommended that the media should be physically destroyed before disposal.

For overwriting magnetic media (e.g. magnetic hard disk), it is important for B/Ds to deploy common overwrite procedures to clean up all the areas of hard disk as far as possible, including those not mapped to active Logical Block Addressing (LBA) addresses (e.g. defect areas and currently unallocated space). For example, 3 overwrite passes (use all binary zero for the first pass, use all binary one for the second pass and use random bits for the last pass) with verification check. For overwriting, data sanitisation tools provided by the manufacturer of the storage media should be

used to erase all data held in the storage media, if applicable. Moreover, specific software utilities may be more effective for overwriting than native read/write utility.

As some storage devices (e.g. Solid Stated Drive (SSD) or flash drives) use different read/write mechanism, the overwrite pass may not be effective in sanitising the data under such media. Therefore, B/Ds are advised to take into consideration of the availability of data sanitisation tools when procuring such storage devices, particularly SSD.

Annex A: Sample Template of Record of Secure Disposal of Storage Media

Sample Template of Record of Secure Disposal of Storage Media

Bureau / Department (B/D) name:	
B/D reference no.:	
Storage media type: <i>(note 1)</i>	
Storage media serial no.: <i>(note 2)</i>	
Number of storage media:	
Data disposal method: <i>(note 3)</i>	
Data disposal standards: <i>(note 4)</i>	
Tool used: <i>(note 5)</i>	
Performed by: <i>(note 6)</i>	
Printed name:	
Post title:	
Signature:	
Company chop:	
Date:	
Sample checked storage media serial no.: <i>(note 2)</i>	
Number of sample checked storage media:	
Sample checked by: <i>(note 7)</i>	
Printed name:	
Post title:	
Signature:	
Company chop:	
Date:	

Note 1: Types of mobile devices: such as portable computers, mobile phones, tablets, digital cameras, audio or video recording devices.

Types of removable media: such as hard disk drives, solid-state drives, floppy disks, zip disks, optical disks (CDs, DVDs, Blu-ray discs and MO disks), tapes, memory cards, flash drives, similar USB storage devices, embedded flash memory on boards and devices, EAPROM (Electrically Alterable Programmable Read-Only Memory), EEPROM (Electrically Erasable Programmable Read-Only Memory).

Types of equipment: such as multi-function printers, photocopiers, fax machines, Internet-of-Things (IoT) devices.

Note 2: Serial no. of storage media should be recorded except for those without serial no. such as compact disk.

Note 3: Data destruction method must be overwriting, degaussing, or physical destruction. B/Ds should maintain one form for each type of disposal method.

Note 4: Disposal of storage media must comply with the standards articulated in the Section 10.3(b) “Information Erasure” of IT Security Guidelines (G3). (At **Annex E**)

If other standards are used, those standards must at least meet the requirements as stated in Section 10.3(b) “Information Erasure” of IT Security Guidelines (G3). (At **Annex E**)

Note 5: For hardware tool, please write the brand/products name and model no. For software tool, please write the name and version no.

Note 6: B/D name if performed in-house; company name if performed by outsourced contractor. The party who performs the disposal of storage media must follow the requirements as stated in Section 10.3(b) "Information Erasure" of IT Security Guidelines (G3) (At **Annex E**) to ensure that all information shall be completely cleared or destroyed and cannot be recovered.

Note 7: B/D name if sample checked by in-house staff; company name if sample checked by outsourced contractors. Sample check of disposed items must be performed by another party (i.e. the personnel who were not part of the original disposal action) to ensure all information was properly disposed in compliance with Section 10.3(b) “Information Erasure” of IT Security Guidelines (G3). (At **Annex E**)

Annex B: Sample Record of Secure Disposal of Storage Media Performed by In-house Staff

Sample Record of Secure Disposal of Storage Media Performed by In-house Staff

Bureau / Department (B/D) name:	DPO
B/D reference no.:	IE-PC-0001
Storage media type: <i>(note 1)</i>	Portable computer
Storage media serial no.: <i>(note 2)</i>	N9TT-9G0A, QK6A-JI6S, SXFP-CHYK, XNSS-HSJW, NHLE-L6MI
Number of storage media:	5
Data disposal method: <i>(note 3)</i>	Overwriting
Data disposal standards: <i>(note 4)</i>	[Data disposal standards]
Tool used: <i>(note 5)</i>	WipeDrive 7
Performed by: <i>(note 6)</i>	DPO
Printed name:	TM CHAN
Post title:	SM
Signature:	[signature]
Company chop:	N/A
Date:	[dd.mm.yyyy]
Sample checked storage media serial no.: <i>(note 2)</i>	SXFP-CHYK
Number of sample checked storage media:	1
Sample checked by: <i>(note 7)</i>	DPO
Printed name:	MT LEUNG
Post title:	SSM
Signature:	[signature]
Company chop:	N/A
Date:	[dd.mm.yyyy]

Annex C: Sample Record of Secure Disposal of Storage Media Performed by Outsourced Contractor

Sample Record of Secure Disposal of Storage Media Performed by Outsourced Contractor

Bureau / Department (B/D) name:	DPO
B/D reference no.:	IE-HD-0001
Storage media type: <i>(note 1)</i>	Hard disks
Storage media serial no.: <i>(note 2)</i>	VPJ9EA59, VRDKP8BH, VX9TQY4B, WJ328M4W, AT55UGS3, XTT5U2PP, XUQSW2WX, Y739E2PH, ACRQA85E, Z9RWJQ4E
Number of storage media:	10
Data disposal method: <i>(note 3)</i>	Degaussing
Data disposal standards: <i>(note 4)</i>	[Data disposal standards]
Tool used: <i>(note 5)</i>	Hard Drive and Tape Degausser DG03
Performed by: <i>(note 6)</i>	Data Erasure Technology Limited
Printed name:	DE LEUNG
Post title:	Engineer
Signature:	[signature]
Company chop:	
Date:	[dd.mm.yyyy]
Sample checked storage media serial no.: <i>(note 2)</i>	VRDKP8BH, WJ328M4W, XUQSW2WX, ACRQA85E, Z9RWJQ4E
Number of sample checked storage media:	5
Sample checked by: <i>(note 7)</i>	Data Erasure Technology Limited
Printed name:	Diana WONG
Post title:	Services Manager
Signature:	[signature]
Company chop:	
Date:	[dd.mm.yyyy]

Annex D: Security controls to prevent data loss during media disposal

The following is a list of security controls to prevent data loss during disposal of storage media:

- Use secure methods such as secure erasure or physical destruction of storage media containing sensitive information after use.
- Setup procedures to identify items that require secure disposal (e.g. RESTRICTED information or above).
- If not sure, treat all storage media as if containing sensitive information during disposal.
- Carefully select contractors when using outsource service for secure disposal; government staff should escort the transportation of storage media to contractors (in case of off-site erasure) and confirm that the storage are securely erased/destroyed.
- Properly log the destruction of data and disposal of storage media to maintain audit trail.
- Verify that the secure erasure of sensitive information is finished before disposal or re-use.
- Use specialised tools for information erasure to ensure the information is non-retrievable; do not use standard delete or format function.
- Perform risk assessment for damaged storage media containing sensitive information to determine necessity of physical destruction instead of repair.

Annex E: Relevant IT Security Policies and Guidelines

Section 10.3.3 of Baseline of IT Security Policy (S17)

All classified information shall be completely cleared or destroyed from storage media before disposal or re-use.

Section 10.3 (b) “Information Erasure” of IT Security Guidelines (G3)

All classified information shall be completely cleared or destroyed from media before disposal, or reuse, by means of (a) Sanitisation or (b) Physical Destruction to ensure that the classified information cannot be recovered:

(a) Sanitisation: refers to the process of removing the data on the media to ensure that the original data cannot be retrieved. Sanitising may be accomplished by overwriting or degaussing:

(i) Overwriting

For any media which has been used for the storage of classified information, the procedure of overwriting ALL addressable locations with a character, its complement, then a random character and verify, shall be performed before disposal or re-use. It is very important that every bit of storage space in the media shall be overwritten. For flash memory devices such as solid-state drives (SSD) or flash drives, the manufacturers normally provide built-in commands ³, which provide effective sanitisation that destroys the entire drive data and not just overwrite or erase the cryptographic keys. Such functions should be used. Nevertheless, if it is not possible to verify that the media has been effectively sanitised and ensure that the original data cannot be retrieved, alternative sanitisation or physical destruction methods that can be verified shall be used.

³ B/Ds are advised to take into consideration of the availability of data sanitisation functions when procuring flash memory devices, particularly SSDs.

(ii) Degaussing

Degaussing or demagnetising is considered an acceptable technical solution for the destruction of classified information stored on magnetic media such as hard disks, floppy disks and magnetic tapes if properly employed. For degaussing hard disks, all shielding materials (e.g. castings, cabinets, and mounting brackets), which may interfere with the degausser’s magnetic field, shall be removed from the hard disks before degaussing. Hard disk platters shall be in a particular position or direction as specified by the degausser during the degaussing process.

Sufficient checks and balances mechanisms shall be in place such as requiring the individual who performs the degaussing to certify the completion of the degaussing.

Sample check of the degaussed media shall also be performed by another party to ensure that the degaussing is done properly.

- (b) Physical Destruction: storage media that cannot be sanitised shall be physically destroyed by means of shredding, disintegration or grinding.

For flash memory devices, the media shall be shredded or disintegrated into particles that have nominal edge dimensions of 2 millimetres or less.

For optical storage media (CDs, DVDs, Blu-ray discs and MO disks), the media shall be shredded or disintegrated to particles:

- that have nominal edge dimensions of 0.5 millimetres or less and surface area of 0.25 square millimetres or less if the media has been used for the storage of information classified as higher than CONFIDENTIAL; or
- that have nominal edge dimensions of 2 millimetres or less if the media has been used for the storage of CONFIDENTIAL or RESTRICTED information.

Alternatively, the CD media can be destroyed by grinding to remove the information bearing surface.

For any media which has been used for the storage of information classified as higher than CONFIDENTIAL, apart from the above procedure of sanitising the media, it is also recommended that the media be physically destroyed before disposal.

In order to comply with the requirements, appropriate tools shall be used to overwrite the storage area where the classified information was originally stored in the media. Commercial software for secure deletion of information is available which conforms to the industry best practice of writing over the storage area several times, including writing with different patterns, to ensure complete deletion. Whole disk sanitisation should be used instead of individual file sanitisation to ensure complete erasure of information for flash-based solid state disks or USB flash drives as completely overwriting a particular file may not be feasible.

Cryptographic erasure may be considered as an alternative approach for data sanitisation which overwrites the cryptographic keys used to encrypt the data, but it is susceptible to risks such as vulnerable encryption algorithm, undeleted backup keys and sanitisation assurance problem. B/Ds shall assess the associated risks and possible impacts before implementing cryptographic erasure. Cryptographic erase shall not be used alone as a sanitisation method for destruction of classified information. Cryptographic erasure can be used in combination with other sanitisation and physical destruction methods for destruction of classified information.

A system of checks and balances shall be maintained to verify the successful completion of the secure deletion process. Sample check of the storage media should

be performed by another party to ensure all classified information was properly cleared or destroyed.

Users should adopt erasure procedures which are similar for RESTRICTED information if they believe that the computer or storage media to be disposed of or re-used contains information which will cause data privacy problems.